

TRƯỜNG ĐẠI HỌC XÂY DỰNG HÀ NỘI
KHOA CÔNG NGHỆ THÔNG TIN



Bài tập lớn môn: An toàn bảo mật thông tin

Đề tài: Tìm hiểu về OTP và ứng dụng

Sinh viên	MSSV	Lớp
Trần Đức Lương	1502368	68IT3
Nguyễn Như Kiên	0015768	68IT3
Phan Thế Kiệt	0015968	68IT3
Giảng viên hướng dẫn:	Th.S Nguyễn Việt Nhật	

Hà Nội, 04/2025

LỜI NÓI ĐẦU

Trong thời đại công nghệ số phát triển mạnh mẽ, sự phát triển của Internet đã làm gia tăng nhu cầu trao đổi thông tin và sử dụng dịch vụ trực tuyến, đồng thời kéo theo những rủi ro mất an toàn thông tin như đánh cắp tài khoản ngân hàng, giao dịch trực tuyến. Để đối phó với các mối nguy này, nhiều giải pháp bảo mật đã được triển khai như quản lý tài khoản bằng Username và Password, sử dụng tường lửa, hệ thống phát hiện xâm nhập, và các công cụ quét mã độc.

Tuy nhiên, việc chỉ sử dụng Username và Password truyền thống dễ bị tấn công nếu máy tính người dùng nhiễm phần mềm gián điệp hoặc thông tin bị nghe lén trên đường truyền. Vì vậy, các nhà cung cấp dịch vụ đã áp dụng các phương pháp xác thực mạnh hơn, kết hợp nhiều yếu tố như Username, Password, mã PIN và sinh trắc học.

Đặc biệt, phương pháp xác thực mật khẩu sử dụng một lần (OTP) đang rất phổ biến trong giao dịch ngân hàng, thanh toán và mua sắm trực tuyến. OTP mang lại tính an toàn cao, linh hoạt và tiện lợi khi có thể gửi qua SMS, Email hoặc thiết bị Token, giúp bảo vệ hiệu quả người dùng và hệ thống trong quá trình xác thực giao dịch quan trọng.

Chính vì vậy nhận thấy tầm quan trọng của OTP trong việc bảo mật dữ liệu của người dùng, nhóm em đã chọn đề tài về mã xác thực OTP để tìm hiểu và nghiên cứu. Trong quá trình làm bài chúng em không tránh khỏi sai sót, nhóm em rất mong nhận được sự góp ý từ quý thầy cô để đề tài nhóm chúng em được hoàn thiện hơn. Em xin chân thành cảm ơn!

MỤC LỤC

CHƯƠNG 1. OTP, ỨNG DỤNG VÀ CÁCH SINH MÃ OTP	4
1.KHÁI NIỆM OTP	4
2.CÁCH TẠO OTP	6
2.1. Các bước tạo mã TOTP	6
2.1.1 Tạo và phân phối khóa bí mật	6
2.1.2 Tính toán giá trị thời gian	6
2.1.3 Tạo mã HMAC (HMAC-SHA1)	7
2.1.5 Rút gọn mã số	7
2.1.6 Gửi mã OTP tới người dùng	7
2.2 Các phương pháp OTP khác	8
3.VẤN ĐỀ AN TOÀN CỦA OTP	8
3.1.OTP có thể bị đánh bại	8
3.2.Làm thế nào để cải thiện OTP?	11
4. LẬP TRÌNH CHƯƠNG TRÌNH SINH MÃ OTP	12
CHƯƠNG 2. KẾT LUẬN	17
2.1 KẾT LUẬN	17
2.2 HƯỚNG PHÁT TRIỂN CỦA ĐỀ TÀI TRONG TƯƠNG LAI	17

MỤC LỤC HÌNH ẢNH

Hình 1: Chương trình sinh mã OTP	12
Hình 2: Chương trình sinh mã OTP	13
Hình 3: Khởi chạy chương trình	15
Hình 4: Chương trình chạy với mã OTP hợp lệ	15
Hình 5: Chương trình xử lý mã OTP không hợp lệ	16

CHƯƠNG 1. OTP, ỨNG DỤNG VÀ CÁCH SINH MÃ OTP

1.KHÁI NIỆM OTP

Chúng ta thường nghe tới xác thực mã OTP, vậy trước tiên ta cần hiểu “Xác thực” là gì?

Xác thực , quá trình xác định và xác thực một cá nhân là bước cơ bản trước khi cấp quyền truy cập vào bất kỳ dịch vụ được bảo vệ nào (chẳng hạn như tài khoản cá nhân). Xác thực đã được tích hợp vào các tiêu chuẩn bảo mật mạng và cung cấp khả năng ngăn chặn truy cập trái phép vào các tài nguyên được bảo vệ. Các cơ chế xác thực ngày nay tạo ra một cổng hai lớp trước khi mở khóa bất kỳ thông tin được bảo vệ nào. Lớp bảo mật hai lớp này, được gọi là xác thực hai yếu tố, tạo ra một con đường yêu cầu xác thực thông tin xác thực (tên người dùng/email và mật khẩu) theo sau là tạo và xác thực Mật khẩu một lần (OTP)

Xác thực OTP, hay xác thực One-Time Password (mật khẩu một lần), là một quy trình bảo mật trong đó một mã duy nhất và tạm thời được gửi đến người dùng qua SMS (Short Message Services: dịch vụ tin nhắn ngắn) hoặc dựa trên ứng dụng có thể quét mã QR (Quick response code: mã phản hồi nhanh) . Người dùng phải nhập mã này để xác nhận danh tính của họ và hoàn tất một hành động cụ thể, chẳng hạn như đăng nhập vào tài khoản, thực hiện giao dịch hoặc truy cập thông tin nhạy cảm. Xác minh OTP bổ sung thêm một lớp bảo mật bằng cách đảm bảo rằng chỉ những cá nhân được ủy quyền có quyền truy cập vào OTP hợp lệ mới có thể tiến hành hành động đã định.

Việc triển khai xác minh OTP mang lại một số lợi ích chính cho cả doanh nghiệp và người dùng. Dưới đây là một số lợi ích mà xác minh OTP mang lại:

1. Tăng cường bảo mật

Một trong những lợi ích chính của xác minh OTP là tính bảo mật được tăng cường mà nó cung cấp. Mật khẩu tĩnh truyền thống dễ bị tấn công bằng nhiều cách khác

nhau, chẳng hạn như tấn công bằng brute-force hoặc đoán mật khẩu. Với xác minh OTP, mỗi lần đăng nhập đều yêu cầu một mật khẩu duy nhất hết hạn sau một thời gian ngắn hoặc sau khi đã sử dụng. Điều này làm giảm đáng kể nguy cơ truy cập trái phép và bảo vệ tài khoản người dùng khỏi các yếu tố độc hại.

2. Xác thực hai yếu tố (2FA)

Xác minh OTP thường được sử dụng như một phần của quy trình xác thực hai yếu tố (2FA: Two-Factor Authentication) . 2FA kết hợp thông tin cái mà người dùng biết (VD: mật khẩu, mã pin,...) với thông tin cái mà người dùng có (VD: OTP, token, điện thoại,...) và cái thuộc về bản thân người dùng (VD: Vân tay, khuôn mặt, giọng nói,...) để cung cấp thêm một lớp bảo mật. Phương pháp xác thực đa yếu tố này làm giảm đáng kể nguy cơ truy cập trái phép, vì kẻ tấn công sẽ cần cả thông tin đăng nhập của người dùng và mật khẩu một lần để xâm nhập.

3. Xác thực không cần mật khẩu

Xác minh OTP cũng cho phép xác thực không cần mật khẩu, giúp người dùng không cần phải nhớ và quản lý nhiều mật khẩu. Thay vì dựa vào mật khẩu tĩnh, người dùng có thể nhận mật khẩu một lần qua SMS, email hoặc ứng dụng xác thực để xác thực danh tính của họ. Xác thực không cần mật khẩu có nhiều lợi ích như không chỉ cải thiện trải nghiệm của người dùng mà còn loại bỏ nguy cơ vi phạm bảo mật liên quan đến mật khẩu.

4. Bảo vệ chống lại Bot và Spam

Xác minh OTP là biện pháp hiệu quả để chống lại bot và tin nhắn spam:

- Bot là một phần mềm được tạo ra để thực hiện các tác vụ trực tuyến một cách tự động. Mặc dù tên "bot" mang hàm ý tiêu cực, nhưng không phải tất cả chúng đều như vậy. Ví dụ, trình thu thập dữ liệu của Google cũng là bot! . Chúng thực hiện các hoạt động phạm tội như tấn công DDoS, gửi thư rác và đánh cắp danh tính

- Thư rác: là các tin nhắn lừa người dùng nhấp vào link độc hại, tải về tệp đính kèm mang mã độc, hoặc điền thông tin cá nhân (phishing: là hình thức kẻ gian giả mạo tổ chức, cá nhân hoặc dịch vụ uy tín để lừa người dùng thực hiện một hành động có hại). trong trường hợp gửi quá tải, nó trở thành tấn công DoS (là hình thức tấn công hệ thống bằng 1 lượng lớn truy cập) ở lớp ứng dụng.

Bằng cách yêu cầu mật khẩu một lần cho mỗi lần đăng nhập hoặc giao dịch, doanh nghiệp có thể đảm bảo rằng chỉ có người dùng thực sự mới truy cập vào hệ thống của họ. Bot và kẻ gửi thư rác thường dựa vào các công cụ tự động không thể tạo hoặc sử dụng OTP, khiến chúng khó xâm nhập vào hệ thống hơn nhiều. Do đó, nó bổ sung thêm một lớp bảo mật cho nền tảng của bạn.

5. Xác minh toàn cầu

Xác minh OTP là phương pháp xác thực đa năng có thể triển khai trên toàn cầu. Với khả năng cung cấp mật khẩu một lần qua SMS hoặc email, các doanh nghiệp có thể xác minh người dùng từ bất kỳ đâu trên thế giới. Điều này khiến xác minh OTP trở thành giải pháp thiết thực cho các tổ chức có cơ sở người dùng toàn cầu hoặc những tổ chức hoạt động ở nhiều quốc gia.

2.CÁCH TẠO OTP

2.1. Các bước tạo mã TOTP

Dưới đây là mô tả chi tiết các bước để tạo một mã OTP theo chuẩn TOTP:

2.1.1 Tạo và phân phối khóa bí mật

Máy chủ (thường là máy chủ backend hoặc máy chủ xác thực) sẽ tạo ra một khóa bí mật (secret key).

Khóa bí mật này thường là một chuỗi ký tự được mã hóa theo Base32.

Sau đó, máy chủ chia sẻ khóa bí mật này với ứng dụng OTP của người dùng (thường bằng cách quét mã QR khi đăng ký 2FA).

2.1.2 Tính toán giá trị thời gian

Giá trị thời gian hiện tại được tính dưới dạng timestamp Unix, tính bằng số giây kể từ 00:00:00 ngày 1 tháng 1 năm 1970 (UTC).

Để mã OTP thay đổi mỗi 30 giây, người ta chia thời gian hiện tại (tính theo giây) cho 30 và làm tròn xuống. Kết quả chính là bộ đếm thời gian (counter).

2.1.3 Tạo mã HMAC (HMAC-SHA1)

Một hàm băm mã xác thực thông điệp (HMAC) được tạo bằng cách sử dụng khóa bí mật và giá trị thời gian đã tính được ở bước trước.

HMAC này thường được mã hóa bằng thuật toán SHA-1 để đảm bảo tính an toàn và nhất quán.

Ví dụ: HMAC-SHA1 có thể tạo ra một chuỗi

"0215a7d8c15b492e21116482b6d34fc4e1a9f6ba"

2.1.4 Cắt bớt HMAC để tạo mã OTP

Kết quả HMAC có độ dài 20 byte (tương đương với 40 ký tự hex). Mỗi byte chiếm 8 bit, mỗi ký tự hex đại diện cho 4 bit.

Dùng phương pháp truncate động (Dynamic Truncation):

- + Xác định vị trí offset từ ký tự cuối cùng của chuỗi hex (giả sử ký tự cuối là "a" → decimal là 10).

- + Từ vị trí đó, lấy 31 bit tiếp theo (tương đương khoảng 8 ký tự hex).

- + Giả sử ta lấy được chuỗi "6482b6d3", chuyển sang số thập phân sẽ cho kết quả là 1686288083.

2.1.5 Rút gọn mã số

Dựa trên độ dài mong muốn của mã OTP (thường là 6 hoặc 8 chữ số), ta lấy số vừa tính được mod cho 10^n .

- + Ví dụ: $1686288083 \bmod 1000000 = 288083$

- + Mã OTP là: 288083

Nếu số thu được có ít hơn n chữ số, có thể thêm số 0 ở đầu.

2.1.6 Gửi mã OTP tới người dùng

Mã OTP này sau đó sẽ được gửi tới người dùng thông qua các kênh như:

+Ứng dụng tạo mã OTP (Google Authenticator, Authy...)

+Tin nhắn SMS

+Email

+Thiết bị phần cứng như token RSA SecureID

2.2 Các phương pháp OTP khác

Ngoài TOTP, còn có các phương pháp tạo OTP khác như:

HOTP (HMAC-based One-Time Password):

- Dựa trên bộ đếm thay vì thời gian. Mỗi lần người dùng xác thực, bộ đếm tăng lên.

Chuỗi một chiều (One-way function):

- Mỗi OTP tiếp theo được tạo ra bằng cách áp dụng một hàm băm lên OTP trước đó.
- Khó dự đoán, vì phải biết giá trị trước đó.

3.VẤN ĐỀ AN TOÀN CỦA OTP

3.1.OTP có thể bị đánh bại

OTP là phiên bản nâng cấp của việc xác thực chỉ sử dụng mật khẩu. Tuy nhiên, OTP không phải là giải pháp hoàn chỉnh cho vấn đề bảo mật.

OTP không phải là giải pháp an toàn tuyệt đối cho bảo mật

Theo Merritt Maxim, phó chủ tịch kiêm giám đốc nghiên cứu tại Forrester Research (công ty nghiên cứu thị trường của Hoa Kỳ cung cấp lời khuyên về tác động tiềm tàng và tiềm ẩn của công nghệ tới khách hàng) cho biết: “OTP có thể bị đánh bại không? Câu trả lời là có. Nhưng chúng là một lớp bổ sung, và nếu tin tặc tìm thấy

một hệ thống chỉ sử dụng mật khẩu so với một hệ thống có mật khẩu và OTP, nhiều khả năng chúng sẽ nhắm vào đến hệ thống chỉ sử dụng mật khẩu trước”.

Tuy nhiên, đối với những kẻ tấn công có động cơ, lớp xác thực bổ sung đó không khó bị đánh bại so với các phương pháp xác thực khác, chẳng hạn như sinh trắc học hoặc khóa cứng.

Phương pháp phổ biến nhất để nhận OTP là qua tin nhắn SMS hoặc email

Mặc dù bảo mật của chúng không hoàn hảo, nhưng OTP đã cho phép các công ty khắc phục một vấn đề xác thực lớn: Cải thiện bảo mật mà không ảnh hưởng tiêu cực đến UX (*User Experience: trải nghiệm của người dùng*). Các yêu cầu bảo mật ngày càng cao gây ra sự mâu thuẫn có thể dẫn đến việc mất khách hàng và công việc kinh doanh.

Tuy nhiên trong kinh doanh, người sử dụng lao động có quyền kiểm soát nhân viên nhiều hơn và có thể yêu cầu các yếu tố xác thực dễ dàng hơn. Nhưng vấn đề nằm ở chi phí và sự sẵn lòng của nhân viên. Loại công nghệ OTP nào mà một công ty có thể đủ khả năng chi trả? Mua khóa phần cứng cho mỗi nhân viên không hề rẻ hay liệu nhân viên sẽ sử dụng thiết bị riêng của họ cho công việc? Nhiều người có thể không muốn cài đặt ứng dụng xác thực trên thiết bị cá nhân của họ.

Ngoài chi phí và trải nghiệm người dùng là thách thức trong việc ngăn chặn và bảo vệ trước các cuộc tấn công OTP.

Các cuộc tấn công OTP phổ biến

Những kẻ tấn công có thể lạm dụng OTP theo nhiều cách, bao gồm đánh cắp mã SMS, hoán đổi SIM và tấn công chiếm đoạt email.

(1)_Đánh cắp mã SMS

Giao thức SMS được tạo ra khi điện thoại cố định vẫn thịnh hành. Vào thời điểm đó, không có thể ai nói trước được các vấn đề an ninh trong tương lai. Allan chia sẻ: “ Với việc SMS “ngu ngốc” như thế nào, các công ty có thể bị hạn chế về khả năng cải thiện bảo mật cho phương pháp này”.

Hệ thống báo hiệu số 7 (SS7) được giới thiệu vào những năm 1970. Nó cho phép chuyển cuộc gọi và tin nhắn SMS giữa các mạng điện thoại. Các lỗ hổng trong SS7 đã cho phép những kẻ tấn công truy cập vào cùng một thông tin mà các công ty điện thoại có, bao gồm cả khả năng đọc các tin nhắn văn bản.

Những kẻ tấn công cũng có thể đánh cắp thông tin đăng nhập của người dùng thông qua các chiến thuật lừa đảo phishing và tấn công phi kỹ thuật. Sau đó chúng lợi dụng các lỗ hổng trong SS7, tiến hành các cuộc tấn công man-in-the-middle (MitM) để đánh cắp hoặc xem trộm các SMS OTP.

(2)_Tráo SIM

Việc tráo đổi SIM liên quan đến tấn công phi kỹ thuật để lừa nhân viên của công ty điện thoại chuyển số điện thoại của khách hàng sang một thiết bị và thẻ SIM mới. Kẻ tấn công thu thập thông tin của một khách hàng cụ thể để nghe có vẻ thuyết phục trong cuộc trò chuyện với một công ty điện thoại. Ngoài ra, kẻ tấn công có thể hối lộ để phi vụ trót lọt.

Poller cho biết: “Một nhân viên cửa hàng có thể truy cập vào tài khoản thường được trả vài trăm Đô La một tuần từ sếp của họ, vì vậy họ hoàn toàn có khả năng chấp nhận một lời đề nghị trị giá 500 đô la”.

Phương pháp tấn công này vẫn phổ biến hiện nay, Poller nói thêm. Anh ấy kể lại trải nghiệm gần đây khi một người bạn trở thành nạn nhân của một vụ tráo SIM và bị rút sạch tiền từ ví điện tử.

Một nghiên cứu của Đại học Princeton cho thấy 80% các cuộc tấn công tráo SIM đã trót lọt.

(3)_Hack email

Hệ thống xác thực hai yếu tố cho phép SMS hoặc email làm yếu tố xác thực thứ hai, những yếu tố này cũng có khả năng bị lừa đảo để chiếm đoạt thông tin. Một báo cáo năm 2021 của IBM cho thấy 17% doanh nghiệp bị xâm phạm trực tiếp do các cuộc tấn công email.

Nếu một tài khoản email chỉ được bảo vệ bằng mật khẩu, những kẻ tấn công có thể chiếm đoạt tài khoản bằng cách sử dụng MitM hoặc tấn công phi kỹ thuật và sau đó lợi dụng các mã OTP nhận được để chiếm đoạt tài khoản.

3.2.Làm thế nào để cải thiện OTP?

Theo các chuyên gia bảo mật, đối với người dùng, việc không chia sẻ OTP là vô cùng quan trọng nếu không muốn trở thành nạn nhân của các giao dịch lừa đảo. Do đó, hãy luôn chắc chắn rằng các mã OTP chỉ riêng bạn thấy, chỉ riêng bạn dùng, không có thêm bất kỳ một người thứ hai nào khác. Đồng thời, trước khi quyết định nhập mã OTP vào bất kỳ trang thông tin hay ứng dụng nào cũng đều nên kiểm tra tính chính chủ và mức độ đáng tin cậy của trang.

Bên cạnh đó, khi nhận được một đường link từ nguồn không rõ hoặc không quen thuộc, đừng nhấp ngay mà kiểm tra xem link có xuất phát từ một nguồn đáng tin cậy hay không. Ngoài ra, bạn nên sử dụng phần mềm chống malware (mã độc) và chống phishing (lừa đảo) để bảo vệ thiết bị của mình, hạn chế tối đa các nguy cơ có thể xảy ra bất kỳ lúc nào.

4. LẬP TRÌNH CHƯƠNG TRÌNH SINH MÃ OTP

```
demo_OTP.py > OTPManager
1  import secrets
2  import threading
3  import time
4  # Hàm sinh khóa bí mật ngẫu nhiên
5  def generate_secret_key():
6      return secrets.token_hex(16) # 16 byte => 32 ký tự hex
7  # Hàm sinh mã OTP một lần với độ dài mặc định là 6 ký tự
8  def generate_otp(length=6):
9      allowed_characters = "0123456789"
10     return ''.join(secrets.choice(allowed_characters) for _ in range(length))
11 class OTPManager:
12     def __init__(self, expiry=60):
13         self.expiry = expiry # Thời gian hiệu lực (giây)
14         self.otp = None # Biến lưu mã OTP hiện tại
15         self.timer = None # Timer làm mới OTP
16         self.countdown_stop = threading.Event()
17         self.refresh_otp()
18
19     def refresh_otp(self):
20         # Sinh mã OTP mới, hiển thị thông báo và khởi động đếm ngược.
21
22         self.otp = generate_otp()
23         print(f"\n[THÔNG BÁO] Mã OTP mới: {self.otp} (hết hạn sau {self.expiry} giây)")
24
25         # Dừng đếm ngược cũ
26         self.countdown_stop.set()
27         self.countdown_stop = threading.Event()
28         threading.Thread(target=self._countdown, daemon=True).start()
29
30         # Hủy timer cũ và lên lịch timer mới
31         if self.timer:
32             self.timer.cancel()
33         self.timer = threading.Timer(self.expiry, self.refresh_otp)
34         self.timer.daemon = True
35         self.timer.start()
36
```

Hình 1: Chương trình sinh mã OTP

```

49     def stop(self):
50         # """ Hủy timer và dừng đếm ngược. """
51         if self.timer:
52             self.timer.cancel()
53         self.countdown_stop.set()
54
55     if __name__ == "__main__":
56         # Sinh khóa bí mật (có thể lưu hoặc không)
57         secret_key = generate_secret_key()
58         print(f"Khóa bí mật (giữ an toàn): {secret_key}\n")
59
60         # Khởi tạo OTP manager với thời gian hiệu lực 60 giây
61         manager = OTPManager(expiry=60)
62         try:
63             while True:
64                 user_input = input("Nhập mã OTP nhận được (gõ 'exit' để thoát): \n")
65                 if user_input.lower() == 'exit':
66                     print("Chương trình kết thúc. Tạm biệt!")
67                     break
68
69                 if user_input == manager.otp:
70                     print("Xác thực OTP thành công. Đã cho phép truy cập!")
71                     break
72                 else:
73                     print("Mã OTP không đúng. Vui lòng thử lại.")
74         finally:
75             manager.stop()
76

```

Hình 2: Chương trình sinh mã OTP

Chương trình trên gồm ba phần chính, hoạt động như sau:

1. Sinh khóa bí mật (secret key)

- Hàm `generate_secret_key()` dùng `secrets.token_hex(16)` để tạo ra một chuỗi 32 ký tự hex ngẫu nhiên (16 byte).
- Khóa này không trực tiếp tham gia vào quá trình tạo OTP ở phiên bản hiện tại, nhưng được in ra để “giữ an toàn” — ta có thể dùng nó để làm cơ sở cho việc ký hoặc xác thực OTP sau này.

2. Tạo mã OTP

- Hàm `generate_otp(length=6)` chọn ngẫu nhiên 6 chữ số (0–9) bằng `secrets.choice`.

- Vì sử dụng module secrets, mỗi mã OTP đều được sinh với độ ngẫu nhiên và bảo mật cao, không thể đoán trước.

3.Quản lý OTP tự động (lớp OTPManager)

Khởi tạo (`__init__`): khi khởi tạo, chương trình gọi hàm `refresh_otp()` để tạo OTP không phải chờ đến khi người dùng bấm gì cả, đồng thời thiết lập các biến:

- `self.expiry`: thời gian hiệu lực (60 giây).
- `self.timer`: một đối tượng `threading.Timer` để tự động gọi lại `refresh_otp()` sau mỗi chu kỳ.
- `self.countdown_stop`: một Event để điều khiển việc dừng luồng đếm ngược khi OTP được làm mới sớm hoặc khi chương trình kết thúc.

Làm mới OTP (`refresh_otp`):

- Gọi `generate_otp()` để có mã mới, ghi vào `self.otp` và in ra màn hình cùng thông báo còn bao nhiêu giây sẽ hết hạn.
- Dừng luồng đếm ngược cũ (nếu có) bằng cách `set()` lên `countdown_stop`, rồi `reset` `countdown_stop` để luồng mới có thể chạy.
- Khởi một luồng nền (daemon) chạy `_countdown()`, liên tục in “Thời gian còn lại: XX giây” mỗi giây, sau đó tự xóa dòng hiển thị khi hết.
- Hủy timer trước đó (nếu đã thiết lập) và tạo một bộ hẹn giờ (Timer) với hàm: `threading.Timer(self.expiry, self.refresh_otp)` để sau hết thời gian đếm ngược, OTP lại được làm mới tự động.

Đếm ngược (`_countdown`):

- Trong vòng `while`, mỗi giây in lại thời gian còn lại, dùng `\r` để không in thêm dòng mới và dùng `flush=True` để chắc chắn hiển thị kịp thời.
- Khi `remaining` về 0 hoặc `countdown_stop` được `set`, vòng lặp dừng và xóa dòng đếm ngược.

Dừng (`stop`):

- Hủy timer nếu còn hoạt động và set countdown_stop để chặn luồng đếm ngược, đảm bảo không còn luồng nền chạy khi thoát.

4. Thực thi chương trình

Sinh khóa bí mật và in ra trên giao diện người dùng.

Tạo một thể hiện OTPManager với biến lưu thời gian tồn tại mã OTP là expiry=60 để bắt đầu sinh mã và đếm ngược tự động.

```
Khóa bí mật (giữ an toàn): 8be03c3bb6d1d73b4993c78ea6f19ab0

[THÔNG BÁO] Mã OTP mới: 029527 (hết hạn sau 60 giây)
Thời gian còn lại: 60 giây. Vui lòng nhập mã: Nhập mã OTP nhận được (gõ 'exit' để thoát):
Thời gian còn lại: 57 giây. Vui lòng nhập mã:
```

Hình 3: Khởi chạy chương trình

Vào vòng while True:

- Yêu cầu người dùng nhập mã OTP hoặc gõ exit để thoát.

Nếu nhập đúng nghĩa là user_input == manager.otp, in thông báo thành công và break.

```
• Khóa bí mật (giữ an toàn): 2f2fa44167ba638ea54a11693999b9da

[THÔNG BÁO] Mã OTP mới: 869272 (hết hạn sau 60 giây)
Thời gian còn lại: 60 giây. Vui lòng nhập mã: Nhập mã OTP nhận được (gõ 'exit' để thoát):
Thời gian còn lại: 52 giây. Vui lòng nhập mã: 869272
Xác thực OTP thành công. Đã cho phép truy cập!
○ PS D:\WORK\Viet>
```

Hình 4: Chương trình chạy với mã OTP hợp lệ

Nếu người dùng nhập sai sẽ đưa ra thông báo “Mã OTP không đúng. Vui lòng thử lại.” và yêu cầu người dùng nhập lại mã.

```
-----BEGIN PGP MESSAGE-----
Khóa bí mật (giữ an toàn): 53feb8d0a90d6997c101767cb8175e39

[THÔNG BÁO] Mã OTP mới: 108702 (hết hạn sau 60 giây)
Thời gian còn lại: 60 giây. Vui lòng nhập mã: Nhập mã OTP nhận được (gõ 'exit' để thoát):
Thời gian còn lại: 56 giây. Vui lòng nhập mã: 123456
Mã OTP không đúng. Vui lòng thử lại.
Nhập mã OTP nhận được (gõ 'exit' để thoát):
Thời gian còn lại: 52 giây. Vui lòng nhập mã: █
```

Hình 5: Chương trình xử lí mã OTP không hợp lệ

CHƯƠNG 2. KẾT LUẬN.

2.1 KẾT LUẬN

Qua bài tập nhóm này, nhóm bọn em đã hiểu thêm về tầm quan trọng trong việc bảo vệ thông tin cá nhân và tài chính của người dùng, đặc biệt trong bối cảnh tội phạm mạng ngày càng tinh vi

Từ bài tập nhóm trên, nhóm em đã được hiểu thêm về phương thức bảo mật bằng mã OTP, cách sinh mã và ứng dụng của mã OTP trong việc bảo vệ dữ liệu và tài khoản của người dùng. Đồng thời chúng em còn học hỏi thêm về kỹ năng làm việc nhóm, kỹ năng tự tìm tài liệu, tổng hợp thông tin và kỹ năng trình bày, viết báo cáo,... nhờ đó giúp chúng em dần hoàn thiện bản thân mình hơn

Nhóm em rất mong có thể nhận được lời nhận xét từ quý thầy cô để giúp đề tài chúng em hoàn thiện hơn, nhóm em xin chân thành cảm ơn!

2.2 HƯỚNG PHÁT TRIỂN CỦA ĐỀ TÀI TRONG TƯƠNG LAI

Trong tương lai nhóm em hi vọng sẽ có thể phát triển nội dung về ứng dụng của OTP nhiều hơn như tạo ra mã QR có thể quét bằng ứng dụng quét mã để hiển thị mã xác thực hay ứng dụng xác thực mã OTP trong những đồ án chuyên ngành sắp tới của những kì học sau.